ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Fortinet FortiGate NGFW (OT/ICS deployment) · Component type: **Network Device (NDR) - OT firewall / IPS** · Target SL = SL 3

Where to work	FortiGate GUI / CLI: **System › Administrators** (accounts, admin profiles, trusted hosts), **System › Settings** (admin access), **Security Profiles › IPS / Application Control** (FortiGuard **OT Security Service** industrial signatures), **Policy & Objects**, **VDOMs**, **Log & Report** / FortiAnalyzer. Baseline against the Fortinet hardening guide.
Interfaces / ports	OT/ICS next-gen firewall. Mgmt: HTTPS (443) + SSH (22) only; SNMP; syslog to FortiAnalyzer/SIEM. Data: zone/VLAN interfaces enforcing the Purdue model; IPsec/SSL VPN for remote.
Notes	NDR (network device) - FortiGate NGFW in an OT/ICS role. Confirm FortiOS version and that a valid **OT Security Service** (industrial IPS + application control) license is active. Wireless is N/A unless a wireless model/AP is in use.
How to read	Read-only: review admin/profile/trusted-host config, security profiles, policies, VDOMs, and logging (GUI/CLI show commands, config backup). Native how-to + external-tool validation + pass. Scans authorized; exploit/DoS only in an isolated environment.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / FortiOS
SR/CR 1.1	Human user identification & auth	Confirm every admin authenticates with a named account (**System › Administrators**); no shared/default admin; central auth via **RADIUS/TACACS+/LDAP** where used; rename/disable the default **admin** or set a strong password + MFA. **Ext. tools:** GUI/CLI (get system admin); attempt default creds (isolated).	Named admins; default admin secured; central auth where used.	
SR/CR 1.2	Software process / device identification	Confirm the FortiGate has a unique host name / serial identity and each management/HA/log partner (FortiManager, FortiAnalyzer, SIEM) is uniquely identified and authenticated. **Ext. tools:** get system status; HA/partner config review.	Unique device identity; management partners identified/authenticated.	
SR/CR 1.3	Account management	Manage admin accounts and **admin profiles** (least privilege - e.g. read-only vs super_admin) centrally; remove unused accounts; scope per-VDOM admins to their VDOM only. **Ext. tools:** GUI (Administrators + Admin Profiles review).	Accounts managed; least-privilege admin profiles; scoped per VDOM.	
SR/CR 1.4	Identifier management	Confirm unique admin identifiers and unique device/interface identities; no reuse; per-VDOM admin identities distinct. **Ext. tools:** Admin/VDOM inventory review.	Unique identifiers; no reuse.	
SR/CR 1.5 / 1.7	Authenticator management & strength	Enforce a strong password policy (**config system password-policy**: length, complexity, expiry, reuse) and MFA (FortiToken/RADIUS) for admins; change all defaults; SSH key auth where used. **Ext. tools:** get system password-policy; MFA config review.	Strong password policy + MFA; no defaults.	
SR/CR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
NDR 1.6	Wireless Access Management (Network)	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded.	N/A
SR/CR 1.8	PKI certificates	Replace the factory self-signed admin/SSL certificate with a CA-signed certificate for the HTTPS admin GUI and SSL-VPN; confirm validity/expiry and chain; manage the trust store. **Ext. tools:** Browser cert view; openssl (:443).	CA-signed admin/VPN certificate; default self-signed replaced.	
SR/CR 1.9	Strength of public key auth	Confirm strong TLS (1.2/1.3) and ciphers on the admin GUI and SSL-VPN, and strong SSH key exchange/ciphers; disable weak protocols/ciphers (SSLv3/TLS1.0/1.1). **Ext. tools:** testssl.sh (:443/SSL-VPN); ssh-audit.	Strong TLS/SSH crypto; weak protocols disabled.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / FortiOS
SR/CR 1.10	Authenticator feedback	Confirm the admin GUI/CLI/SSL-VPN login masks password entry (no cleartext echo). **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Confirm admin-lockout on repeated failures (**config system global** admin-lockout-threshold/duration) and that failures are logged/alerted. **Ext. tools:** get system global (admin-lockout); log review.	Admin lockout on failed logins; attempts logged.	
SR/CR 1.12	System use notification	Confirm the approved pre-login use-notification banner is enabled (**config system global** pre-login-banner / replacement message) on GUI and SSH. **Ext. tools:** Login banner check (GUI/SSH).	Approved use notification presented before access.	
SR/CR 1.13	Access via untrusted networks	Confirm admin access is restricted to **trusted hosts** (per-admin trusthost1..10) and to the management interface/VDOM; disable admin access on untrusted (WAN/plant) interfaces; remote admin only via VPN. **Ext. tools:** get system admin (trusthost); interface admin-access review; Nmap from untrusted side.	Admin restricted to trusted hosts/mgmt; denied from untrusted networks.	
NDR 1.13	Access via untrusted networks (network device)	For the network-device function, confirm management is reachable only from the trusted management zone/VDOM and denied on untrusted (WAN/plant) interfaces; any remote management from untrusted networks is brokered via VPN and monitored. **Ext. tools:** Interface admin-access review; Nmap from untrusted side (mgmt closed).	Management denied from untrusted networks; remote via VPN, monitored.	NDR-specific.

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / FortiOS
SR/CR 2.1	Authorization enforcement	Confirm admin profiles enforce least privilege (read-only monitors, scoped config rights) and that security **policies** are default-deny with explicit allow only for required OT flows/conduits. **Ext. tools:** Admin-profile review; policy review (implicit deny confirmed).	Least-privilege admin rights; default-deny policy base.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use control for portable/mobile devices	Control the appliance USB/console/service ports and any config-restore from removable media; only authorized, signed configuration/firmware is loaded; enforce removable-media policy on the admin workstation. **Ext. tools:** Physical inspection; admin-workstation media policy.	USB/console/config-media use controlled.	
NDR 2.4 (+ SR 2.4)	Mobile code	No general-purpose mobile code runs on the firewall; confirm only Fortinet-signed FortiOS and signed FortiGuard content execute; no untrusted scripts/packages loadable. **Ext. tools:** get system status (firmware signature); FortiGuard update review.	Only signed FortiOS/FortiGuard runs; no untrusted mobile code.	NDR-specific.
SR/CR 2.5	Session lock	Confirm admin idle timeout (**config system global** admintimeout) logs out idle GUI/CLI sessions; SSL-VPN idle timeout set. **Ext. tools:** get system global (admintimeout); SSL-VPN timeout.	Admin/VPN sessions time out on inactivity.	
SR/CR 2.6	Remote session termination	Confirm active admin/VPN sessions can be terminated on demand (diagnose sys admin/session; SSL-VPN de-auth) and idle sessions close. **Ext. tools:** GUI (active admin sessions); CLI de-auth test.	Remote sessions terminable on demand and on inactivity.	
SR/CR 2.7	Concurrent session control	Confirm concurrent admin logins are limited/monitored (e.g. deny multiple concurrent super_admin where policy requires) and active sessions are visible. **Ext. tools:** GUI (concurrent admin sessions review).	Concurrent privileged sessions limited/monitored.	
SR/CR 2.8 / 2.12	Auditable events & non-repudiation	Confirm event/admin/config-change logging is enabled and forwarded via **syslog** to FortiAnalyzer/SIEM with the admin identity, so config and access changes are attributable. **Ext. tools:** Log settings review; SIEM/FortiAnalyzer forwarding.	Admin/config events logged, forwarded, and attributable.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / FortiOS
SR/CR 2.9	Audit storage capacity	Confirm log storage (local disk + FortiAnalyzer/SIEM) is sized and rotated and events are offloaded for retention; alert before capacity. **Ext. tools:** Log disk/quota review; SIEM retention.	Log storage sized; events offloaded and retained.	
SR/CR 2.10	Response to audit processing failures	Confirm defined behavior on log-forwarding/disk failure (alert on log-full / miglogd failure; reliable syslog); events not silently lost. **Ext. tools:** Log-failure alerting; reliable-syslog config.	Defined response to audit failure; alerting on loss.	
SR/CR 2.11	Timestamps	Confirm the FortiGate time is synced (**config system ntp**) to the plant time source so log timestamps are accurate and correlate across devices. **Ext. tools:** get system ntp status.	Reliable, synchronized timestamps.	
NDR 2.13	Physical diagnostic & test interfaces	Control the console/USB/service ports; keep the appliance in a locked rack; disable unused physical/management interfaces; restrict the local console. **Ext. tools:** Physical inspection; interface/console config review.	Physical/diagnostic interfaces controlled; unused ports disabled.	NDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / FortiOS
SR/CR 3.1 / 4.1	Communication integrity & confidentiality	Confirm management traffic uses TLS/SSH only (no HTTP/Telnet), HA heartbeat is protected, and remote/site-to-site traffic uses **IPsec/SSL VPN**; the firewall enforces integrity of transiting OT conduits. **Ext. tools:** Interface admin-access review; Wireshark (mgmt/VPN).	Management and remote comms integrity/confidentiality-protected.	
NDR 3.2	Protection from malicious code (component)	Confirm only Fortinet-signed FortiOS runs and the appliance rejects unsigned firmware; FortiGuard AV/IPS content protects transiting traffic; the device itself has no general code path. **Ext. tools:** Firmware signature; FortiGuard status.	Only signed firmware runs; component protected; content inspection active.	NDR-specific.
SR/CR 3.3	Security functionality verification	After change, re-verify admin/trusted-host settings, security profiles (IPS/OT), policy base, disabled services, and certificates against the hardening baseline; compare the config backup. **Ext. tools:** Config-backup diff; Nmap (confirm disabled mgmt services off).	Configuration matches the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Confirm configuration integrity: signed/encrypted config backups, controlled change process (FortiManager where used), and revision history so unauthorized config changes are prevented/detected. **Ext. tools:** FortiManager/revision review; config-backup integrity.	Config integrity protected; unauthorized change prevented/detected.	
SR/CR 3.5	Input validation	Keep FortiOS patched to current PSIRT advisories (management/parser CVEs are addressed via updates); confirm robustness of exposed management services; fuzz management only in a lab. **Ext. tools:** FortiGuard PSIRT/patch review; mgmt fuzz (ISOLATED).	Patched against known input-validation CVEs; mgmt robust to malformed input.	Do NOT fuzz production.
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error handling	Confirm the appliance handles faults gracefully (HA failover, conserve mode behavior, no info leakage in errors) and recovers without opening the network. **Ext. tools:** HA failover test (lab); log/error review.	Graceful fault handling; fail-closed; no info leak.	
SR/CR 3.8	Session integrity	Confirm management (TLS/SSH) and VPN sessions are integrity-protected against replay/hijack; old sessions cannot be replayed. **Ext. tools:** Wireshark (TLS/SSH session inspection).	Management/VPN sessions integrity-protected.	
SR/CR 3.9	Protection of audit information	Protect logs: restrict who can view/delete local logs, forward to a write-once FortiAnalyzer/SIEM so local tampering cannot erase the trail. **Ext. tools:** Admin-profile (log access) review; SIEM immutability.	Audit records protected from unauthorized read/modify/delete.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / FortiOS
NDR 3.10	Support for updates	Update FortiOS only with **Fortinet-signed** firmware; the appliance validates the image; plan controlled upgrades with a rollback/config-restore path; keep FortiGuard signatures current. **Ext. tools:** Firmware signature verify; FortiGuard update log.	Signed firmware updates only, with a controlled update + rollback path.	NDR-specific.
NDR 3.11	Physical tamper resistance/detection	Keep the appliance in a locked, access-controlled rack; control console/USB; config-change logging records tamper evidence; enable secure-boot/BIOS controls on the platform where supported. **Ext. tools:** Physical inspection; config-change log review.	Rack locked; interfaces controlled; changes logged.	NDR-specific.
NDR 3.12	Provisioning product-supplier roots of trust	The appliance accepts only Fortinet-signed firmware (product-supplier root of trust); confirm the signing chain is intact and unsigned/altered images are rejected at load. **Ext. tools:** Firmware signature verify; attempt unsigned image (isolated) -> rejected.	Supplier signing root intact; unsigned firmware rejected.	NDR-specific.
NDR 3.13	Provisioning asset-owner roots of trust	Confirm the asset owner provisions its own admin/VPN certificates (CA-signed) and can manage the trust store; FortiManager CA where used. **Ext. tools:** Certificate/trust-store review.	Asset-owner certificate provisioning supported and verified.	NDR-specific.
NDR 3.14	Integrity of the boot process	Confirm the appliance validates signed-firmware/secure-boot integrity before execution; no unsigned/tampered image runs. Capture firmware version + integrity status. **Ext. tools:** get system status (firmware/integrity); secure-boot status.	Firmware integrity validated before execution; only signed firmware boots.	NDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / FortiOS
SR/CR 4.2	Information persistence	On decommission/RMA, factory-reset and wipe the configuration/keys/certificates (and disk logs) so credentials and config are not recoverable. **Ext. tools:** Factory reset / disk format; verify wipe.	Sensitive config/keys/logs purged on decommission.	
SR/CR 4.3	Use of cryptography	Confirm modern crypto for admin TLS, SSL/IPsec VPN and SSH (TLS 1.2/1.3, strong IKE/IPsec proposals); disable weak ciphers; protect stored keys. **Ext. tools:** testssl.sh; IPsec proposal review.	Modern crypto in use; weak ciphers disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / FortiOS
SR/CR 5.1 / 5.2 (+ NDR 5.2)	Zone/conduit segmentation & boundary protection	Confirm the FortiGate enforces the zone/conduit model (Purdue): interfaces/VLANs/**VDOMs** separate zones, default-deny policies allow only required OT protocols across boundaries, and it does not bridge unintended traffic. **Ext. tools:** Policy/zone review; Nmap across zones; Wireshark (cross-zone).	Firewall enforces zone/conduit boundaries; only required flows cross.	NDR-specific.
SR/CR 5.3 (+ NDR 5.3)	General-purpose person-to-person comms restrictions	**N/A.** The firewall is a single-purpose network device with no general-purpose person-to-person communications (email/IM/web) hosted on it; it restricts such traffic for other zones via policy but does not originate it. **Ext. tools:** Confirm no such services on the appliance.	N/A - justification recorded (single-purpose network device).	N/A
SR/CR 5.4	Application partitioning	Confirm workload/role separation on the appliance: **VDOMs** partition administrative and traffic domains, per-VDOM admins are scoped, and management is separated from data planes so a compromise is contained. **Ext. tools:** VDOM + admin-scope review.	Domains/roles partitioned (VDOMs) to contain compromise.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / FortiOS
SR/CR 6.1 / 6.2	Audit log accessibility & continuous monitoring	Confirm security/IPS/policy logs are readable/exportable and forwarded to FortiAnalyzer/SIEM for continuous monitoring; OT IPS alerts feed the SOC in near real time. **Ext. tools:** Syslog/FortiAnalyzer forwarding; SIEM alerting.	Events accessible/exportable and monitored in near-real-time.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / FortiOS
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: **DoS policies** / anomaly protection, session/rate limits, HA pair for continuity, and admin access rate-limits so a flood cannot deny the firewall or the protected zone. **Ext. tools:** DoS-policy review; HA status; load test (ISOLATED).	DoS protections configured; HA continuity; resists resource exhaustion.	
SR/CR 7.2	Resource management	Confirm resource controls (session limits, per-policy traffic shaping, conserve-mode thresholds) so a single flow cannot starve the firewall of memory/CPU/sessions. **Ext. tools:** diagnose sys session stat; resource/shaping review.	Resources bounded; no single-flow exhaustion.	
SR/CR 7.3 / 7.4	Backup & recovery	Confirm the configuration is backed up (encrypted, versioned, offline; FortiManager where used) and restore/HA failover is tested for a known-good rebuild. **Ext. tools:** Config-backup review; restore/HA test (lab).	Backups current and recovery/HA validated.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6 / 7.7	Network & security settings + least functionality	Confirm hardening: disable HTTP/Telnet/PING on untrusted interfaces, disable unused services (auto-install, unused VPN, unused protocols), restrict SNMP to v3, per the Fortinet hardening guide. **Ext. tools:** Interface admin-access review; Nmap (exposed services).	Least functionality; unused services disabled per baseline.	
SR/CR 7.8	Component inventory	Confirm FortiOS version, model, licenses (OT/IPS), and signature versions are inventoried so vulnerabilities track against Fortinet PSIRT advisories. **Ext. tools:** get system status; ReadOnlyEnum; license/version inventory.	Accurate firmware/version/license inventory maintained.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
FortiOS GUI / CLI	Native config review (all FRs)	Read admins/profiles/trusted-hosts, security profiles (OT IPS/app-control), policies, VDOMs, logging, NTP, certificates; export config for compare.	Read/authorized; config backup.
Nmap / ReadOnlyEnum	Exposed-service & zone enumeration (1.13, 5.x, 7.6, 7.8)	Enumerate mgmt (443/22/SNMP) and cross-zone reachability; confirm HTTP/Telnet disabled and only required flows cross.	Read-only; authorized.
testssl.sh / ssh-audit	Admin TLS & SSH strength (1.8, 1.9, 4.3)	Check TLS versions/ciphers on the admin GUI and SSL-VPN and SSH KEX/ciphers.	Non-intrusive.
Wireshark	Comms/zone integrity review (3.1, 3.8, 5.x)	Confirm mgmt/VPN channels are encrypted and that only required protocols cross zone boundaries.	Passive capture.
Syslog / FortiAnalyzer + SIEM	Event forwarding & monitoring (2.8-2.10, 6.x)	Confirm admin/config/IPS events reach the SIEM; trigger a test event.	Coordinate with SIEM team.
DoS / traffic generator	DoS resilience (7.1)	High-rate/anomaly testing against a bench firewall while watching sessions/CPU/conserve-mode.	ISOLATED/non-production; authorization.

Controlled - Project Use · Independent Assurance Authority · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.